

SHASHANK BARTHWAL

Senior Security Researcher | Scalable Offensive Security Platform & Detection Engineer

[\[LinkedIn\]](#) [\[Twitter\]](#) [\[GitHub\]](#) [\[Website\]](#) Email: shashankstan7[at]gmail[dot]com Ph:+91 8279792659

EXECUTIVE SUMMARY

Security Researcher with 5+ years of hands-on experience in offensive security, vulnerability research, detection engineering in Web/API/Mobile attack surface, and scalable security platform development. Experienced in discovering and responsibly disclosing security vulnerabilities, authoring advanced Attack Surface Management (ASM) modules, and building high-performance scanning infrastructures. Conference speaker with presentations delivered at leading security events. Passionate about deep technical research, exploit analysis, and engineering security solutions that operate effectively at scale.

WORK EXPERIENCE

Senior Security Researcher (CloudSEK ASM R&D) | CloudSEK

Apr 2023 - Present

- Developed and maintained the API vulnerability scanner project of CloudSEK.
- Built detection signatures for 20+ CVEs and misconfigurations
- Created state of the art Wildcard Filter project to eliminate non-legitimate assets associated with a domain (which reduced the ASM resource consumption and scan duration per asset by 50%).
- Discovered and documented critical security vulnerabilities associated with infrastructure and supply chain such as RCEs, account takeovers, PII exposures, etc.
- Discovered and reported critical security misconfigurations associated with mobile applications such as exposure of sensitive secrets and assets, SSL Certificate Pinning and Root Detection bypasses, Insecure Deserialization, etc.
- Built an AI-powered customer support platform, reducing response time by 70% and operational costs by 60%.

Security Engineer (CloudSEK ASM R&D) | CloudSEK

Apr 2022 - Apr 2023

- Developed the first ASM Web Application Scanner project of CloudSEK and delivered multiple modules such as
 - Vulnerability scanning/detection modules (XSS, Exposed secrets, API endpoints, etc)
 - WebApp classifier project to identify if a customer web application is internal(business critical) or external
 - Passive URL discovery & technology stack detection module
- **Vulnerability Research on 80000+ Android Applications:** Conducted Log4Shell based vulnerability research on hidden mobile application attack surface and found **200+ confirmed RCEs and 400+ SSRFs** across different sectors.
- Discovered and responsibly **disclosed critical 0-day vulnerabilities** in the Appsmith platform (**CVE-2022-38298, CVE-2022-38299**) leading to 1-click Administrator Account Takeover.
- Created bevigil-cli - The first open source project of CloudSEK to **enumerate hidden technical assets from Android applications** for enhanced security scanning coverage.
- Conducted closed research on public postman workspaces leading to **exposure of sensitive secrets, tokens and assets in 10000+ Postman workspaces.**
- Maintained the Subdomain Discovery Pipeline - From addition of new sources, writing test cases and architecture re-design for scalability.

Senior Security Researcher (CloudSEK DRP) | CloudSEK

Oct 2021 - Apr 2022

- Created domain suggestion project to identify domains associated with an organization through passive intelligence from sources like github, fofa, whois and historical DNS data.
- Discovered and documented critical infrastructure security as well as brand security issues to our customers and prospects.
- Created the first google docs based reporting engine for mobile application security reports.

Security Researcher (CloudSEK DRP) | CloudSEK

Aug 2020 - Oct 2021

- Discovered and documented breached credentials, fake websites, fake social media pages, dark web and telegram discussions associated with customers, and build CTF challenges.

SPECIALIZATIONS

Skill	Tools
Attack Surface Management (ASM) Research & Development	Nuclei, CloudSploit, Steampipe, custom enumeration & exploitation tooling, distributed scanning pipelines (RabbitMQ/Redis), Docker, Kubernetes.
Web/API/Mobile Security Penetration Testing/Vulnerability Analysis	Burp Suite, nuclei, ffuf, kiterunner, jadx, apktool, dex2jar, smali, Frida, Objection, AVD, custom tooling, etc.
Event Driven & Distributed Engineering Architecture for Vulnerability Scanners	Python (Advanced), Golang (Basic), RabbitMQ, Redis, MongoDB, Elastic Search, Docker, Kubernetes, etc.
Secure Code Review & Vulnerability Research	Snyk, CodeQL, Java (Spring), Python, PHP, Node.js, Maven, Gradle, Git

ACHIEVEMENTS

- [Offensive Security Certified Professional \(OSCP\)](#)
- Secured 1st Rank in SecuriumX CTF in BSides Vizag (2026)
- Secured 1st Rank in Hack on Hills CTF (2021)
- 200+ Stars on Github Projects
- [IBM Certified Security Intelligence Engineer \(2018\)](#)

PROGRAMMING LANGUAGES

- Production grade experience in Python
- Familiar with Golang, PHP, C, etc

TALKS DELIVERED

Conferences/Meet Up	Link
BSides Ahmedabad 2022	Pwning Android Apps at Scale
BSides Singapore 2022	Speaker Archives: BSides Singapore 2022
Indian Oil Corporation Limited	Cyber Security of Critical Infrastructure in India: A Historical Perspective & Future Outlook
c0c0n 2022	Speaker Archive: c0c0n 2022
CSAXCON 2026	Hacking the Weakest Link: Offensive Learnings from Vendor Supply Chain

PROJECTS

■

Jsmug

The first and most evasive PoC of JSON Smuggling technique to smuggle arbitrary files through insignificant bytes.

Link: <https://github.com/xscorp/jsmug>

bevigil-cli

A CLI tool and python SDK to extract useful assets such as URLs, parameters, fuzzing keywords, subdomains, S3 buckets etc from a global database of assets associated with 1M+ android applications.

Link: <https://github.com/Bevigil/BeVigil-OSINT-CLI>

pingfisher

Pingfisher is a tool to capture ICMPv4 and ICMPv6 ping requests and reply to assist during exploitation of blind vulnerabilities in CTFs.

Link: <https://github.com/xscorp/pingfisher>

EDUCATION HIGHLIGHTS

Institution	Degree	Year
DIT University, Uttarakhand	B.Tech CSE (Cyber Security)	2017-2021
JNV Rudraprayag, Uttarakhand	Higher Secondary (Science)	2015-2017

Blogs

■

- [\[CVE-2023-46604\] ActiveMQ Deserialization RCE Analysis](#)
- [Analysis of exposed .NET DLL Files Leading to Exposure of Customer Data](#)
- [Hard Coded Secrets on Mobile Application Leading to Access Control Bypass on Salesforce Instance](#)
- [Unauthenticated Kong API Instance leading to full control on the application](#)
- [Discovering & Exploiting Full Read SSRF Vulnerability on Appsmith](#)
- [Discovering 1-click Admin Account Takeover on Appsmith](#)

HOBBIES

■

Playing piano, football and diving into Web2 security concepts